

**FATEC BARUERI – PADRE DANILO JOSÉ DE OLIVEIRA OHL**  
**CURSO DE GESTÃO DA TECNOLOGIA DA INFORMAÇÃO**

**DESENVOLVIMENTO E IMPLEMENTAÇÃO**  
**DE UM GATEWAY DE PAGAMENTO PARA A PAVPLAS**

**RAFAEL THIENGO REIS**  
**GUSTAVO SIRQUEIRA SOARES DA SILVA**  
**STANLEY SOUSA DO VALE**  
**CAUÃ AZEREDO GOLDEN RODRIGUES**  
**NAYARA TEIXEIRA DA SILVA**  
**HEITOR SOARES TANAN**  
**BRUNO TEMOTEO DE MACEDO**

**BARUERI – SP**

**2026**

**RAFAEL THIENGO REIS**  
**GUSTAVO SIRQUEIRA SOARES DA SILVA**  
**STANLEY SOUSA DO VALE**  
**CAUÃ AZEREDO GOLDEN RODRIGUES**  
**NAYARA TEIXEIRA DA SILVA**  
**HEITOR SOARES TANAN**  
**BRUNO TEMOTEO DE MACEDO**

**DESENVOLVIMENTO E IMPLEMENTAÇÃO**  
**DE UM GATEWAY DE PAGAMENTO PARA A PAVPLAS**

Monografia apresentada ao curso de Gestão da Tecnologia da Informação como requisito para avaliação acadêmica, contemplando a análise, modelagem, desenvolvimento e validação de uma solução de gateway de pagamento para a empresa PavPlas.

Orientador(a): Prof(a). Vander Ribeiro Elme

**BARUERI – SP**

**2026**

# SUMÁRIO

## **1 INTRODUÇÃO**

1.1 Contextualização

1.2 Problema de Pesquisa

1.3 Justificativa

1.4 Objetivo Geral

1.5 Objetivos Específicos

## **2 REFERENCIAL TEÓRICO**

2.1 Sistemas de Pagamento

2.2 Gateway de Pagamento

2.3 APIs REST

2.4 Integração de Sistemas

2.5 Segurança da Informação

2.6 Banco de Dados

2.7 Engenharia de Software

2.8 LGPD

## **3 METODOLOGIA**

3.1 Tipo de Pesquisa

3.2 Levantamento de Requisitos

3.3 Metodologia de Desenvolvimento

3.4 Mapeamento de Stakeholders

3.4.1 Validação de Stakeholders

## **4 ANÁLISE DO PROBLEMA**

4.1 Processo Atual

4.2 Problemas Identificados

4.3 Processo Proposto

4.4 Requisitos Funcionais

4.4.1 Tabela de Requisitos Funcionais

4.4.2 Regras de Negócio Associadas

4.5 Requisitos Administrativos

4.5.1 Tabela de Requisitos  
Administrativos

4.6 Requisitos Não Funcionais

## **5 MODELAGEM E ARQUITETURA**

**5.1 Visão Geral do Sistema**

**5.2 Arquitetura da Solução**

**5.3 Casos de Uso**

**5.4 Diagrama de Classes**

**5.5 Modelo de Dados**

**5.6 Fluxo de Pagamento**

## **6 SEGURANÇA**

6.1 Autenticação e Autorização

6.2 Proteção de Dados

6.3 Criptografia

6.4 Controle de Acesso

6.5 LGPD

## **7 CONCLUSÃO**

7.1 Considerações Finais

## 7.2 Limitações

## 7.3 Trabalhos Futuros

## RESUMO

O presente trabalho tem por objetivo analisar o processo de vendas e pagamentos da empresa PavPlas, comparando o modelo atual com a proposta de automação futura. Atualmente, o site da empresa funciona apenas como catálogo de produtos, enquanto todo o processo de compra é realizado manualmente por meio do WhatsApp. O cliente entra em contato com a empresa para verificar disponibilidade, negociar valores, definir frete e efetuar pagamentos via PIX ou transferência bancária. Após a confirmação do pagamento, a empresa realiza a separação do produto, emissão da nota fiscal e envio pela transportadora.

O modelo proposto busca modernizar e automatizar esse fluxo, permitindo que o cliente realize toda a compra diretamente pelo sistema online. Entre as melhorias previstas estão carrinho de compras, validação automática de estoque, cálculo de frete, escolha de métodos de pagamento (PIX, boleto e cartão), integração com gateway de pagamento e atualização automática do status do pedido. Além disso, o sistema também realiza integração com os setores de logística e financeiro, garantindo maior controle operacional e financeiro.

Com a implementação do novo processo, espera-se reduzir atividades manuais, aumentar a eficiência, melhorar a experiência do cliente e otimizar a comunicação entre os setores da empresa. Dessa forma, o mapeamento de processos permite identificar falhas no modelo atual e propor soluções tecnológicas mais eficientes e organizadas.

**Palavras-chaves:** Gateway de pagamento. Gestão de Processos. Integração de sistemas. Automação de vendas.

## ABSTRACT

The present study aims to analyze the sales and payment process of the company PavPlas, comparing the current model with the proposed future automation model. Currently, the company's website functions only as a product catalog, while the entire purchasing process is carried out manually through WhatsApp. Customers contact the company to check product availability, negotiate prices, define shipping options, and make payments via PIX or bank transfer. After payment confirmation, the company separates the products, issues the invoice, and ships the order through a carrier company.

The proposed model seeks to modernize and automate this workflow, allowing customers to complete the entire purchase directly through the online system. The planned improvements include a shopping cart, automatic stock validation, freight calculation, selection of payment methods (PIX, bank slip, and credit card), integration with a payment gateway, and automatic updates of the order status. In addition, the system will also integrate with the logistics and financial departments, ensuring greater operational and financial control.

With the implementation of the new process, the expectation is to reduce manual activities, increase efficiency, improve customer experience, and optimize communication between the company's departments. Therefore, process mapping makes it possible to identify flaws in the current model and propose more efficient and organized technological solutions.

**Keywords:** Payment gateway. Process management. Systems integration. Sales automation.

# **1 INTRODUÇÃO**

A crescente evolução tecnológica tem transformado radicalmente a forma como as empresas realizam seus processos de vendas, atendimento e gestão operacional. No atual cenário competitivo, a presença digital deixou de ser um diferencial para se tornar um requisito fundamental de sobrevivência e escalabilidade. Nesse contexto, a Gestão de Processos de Negócio (BPM) e a automação de fluxos operacionais tornaram-se essenciais para aumentar a eficiência, reduzir falhas operacionais e melhorar substancialmente a jornada e a experiência do cliente.

Empresas que ainda utilizam métodos puramente manuais ou descentralizados para a efetivação de suas vendas podem enfrentar severas dificuldades relacionadas à lentidão no atendimento, falta de integração sistêmica entre setores, gargalos no fluxo de caixa e um risco consideravelmente maior de erros humanos durante as etapas de conciliação e pagamento.

## **1.1 Contextualização**

A empresa PavPlas atualmente utiliza um modelo de vendas parcialmente manual, no qual o site institucional funciona apenas como vitrine de produtos, exigindo que o fechamento da compra e o acerto financeiro ocorram de forma assíncrona através do aplicativo de mensagens WhatsApp.

Diante disso, este trabalho tem como objetivo principal analisar detalhadamente o processo atual (cenário As-Is) da empresa e documentar a proposta de um novo modelo estruturado e automatizado de vendas e pagamentos (cenário To-Be). A futura implementação de um Gateway de Pagamento integrado visa otimizar a engrenagem interna, garantir segurança robusta nas transações digitais, melhorar o controle do fluxo de dados e oferecer maior autonomia e praticidade aos consumidores finais.

## **1.2 Problema de Pesquisa**

O processo de vendas da PavPlas depende de atividades manuais e do WhatsApp, desde a negociação até a confirmação do pagamento. A falta de integração entre vendas, estoque, financeiro e logística gera retrabalho, demora e possibilidade de erros. Diante disso, o trabalho busca analisar como um gateway de pagamento integrado

ao processo de vendas pode automatizar e centralizar os pagamentos, aumentar a segurança, reduzir atividades manuais e melhorar a integração entre os setores.

### **1.3 Justificativa**

O projeto é relevante para a PavPlas por buscar reduzir processos manuais, retrabalho e erros no processamento de pagamentos, tornando as vendas mais rápidas e organizadas. Tecnicamente, o desenvolvimento de um gateway integrado permite centralizar e automatizar as transações, além de melhorar a comunicação entre vendas, financeiro e estoque. Academicamente, o projeto possibilita aplicar conhecimentos de desenvolvimento de sistemas, integração de APIs, bancos de dados e segurança da informação em uma situação prática.

### **1.4 Objetivo Geral**

Analisar, modelar e propor o desenvolvimento de um gateway de pagamento integrado ao processo de vendas da PavPlas, visando automatizar e centralizar as etapas de compra e pagamento, reduzir atividades manuais e retrabalho, aumentar a segurança das transações e melhorar a integração entre os setores de vendas, estoque, financeiro e logística.

### **1.5 Objetivos Específicos**

- Levantar e analisar o processo atual de vendas e pagamentos da PavPlas, identificando suas principais etapas, gargalos e limitações;
- Mapear os requisitos funcionais, administrativos e não funcionais necessários para a solução proposta;
- Modelar o fluxo de vendas e pagamentos no cenário futuro (To-Be), considerando a automação das principais atividades;
- Projetar a integração do gateway de pagamento com os sistemas de vendas, estoque, financeiro, logística e ERP;
- Desenvolver uma solução capaz de oferecer diferentes métodos de pagamento, como PIX, boleto bancário e cartão de crédito;
- Implementar mecanismos para atualização automática do status dos pedidos após o processamento dos pagamentos;

- Aplicar medidas de segurança para proteção das informações e das transações realizadas pelo sistema;
- Testar e avaliar a solução proposta, verificando seu funcionamento, integração e atendimento aos requisitos definidos.

## **2 REFERENCIAL TEÓRICO**

[Desenvolver o conteúdo deste capítulo com base no projeto real.]

### **2.1 Sistemas de Pagamento**

[Conceituar pagamentos digitais e seus principais elementos.]

### **2.2 Gateway de Pagamento**

O gateway de pagamento é uma solução tecnológica que atua como intermediária entre o sistema de vendas e os participantes do ecossistema financeiro, permitindo o envio e processamento seguro das informações de uma transação. Por meio de integrações via API, o gateway recebe os dados do pagamento, realiza seu encaminhamento aos serviços responsáveis pelo processamento e retorna ao sistema informações sobre o status da transação, como aprovação, recusa ou pendência. Dessa forma, funciona como um terminal de pagamento virtual, contribuindo para a automatização, segurança e integração do processo de vendas.

### **2.3 APIs REST**

[Apresentar REST, HTTP, endpoints, métodos, JSON, códigos de resposta e boas práticas.]

### **2.4 Integração de Sistemas**

[Abordar comunicação entre sistemas e integração com provedores.]

### **2.5 Segurança da Informação**

[Apresentar autenticação, autorização, criptografia, confidencialidade, integridade, disponibilidade e proteção de credenciais.]

### **2.6 Banco de Dados**

[Apresentar conceitos necessários para persistência e rastreabilidade de transações.]

### **2.7 Engenharia de Software**

[Abordar requisitos, arquitetura, desenvolvimento, testes e manutenção.]

### **2.8 LGPD**

[Apresentar os princípios e cuidados aplicáveis ao tratamento de dados pessoais no sistema.]

### **3 METODOLOGIA**

[Desenvolver o conteúdo deste capítulo com base no projeto real.]

#### **3.1 Tipo de Pesquisa**

[Caracterizar a pesquisa como aplicada e justificar.]

#### **3.2 Levantamento de Requisitos**

[Descrever entrevistas, reuniões, análise de processos, documentos e demais técnicas utilizadas.]

#### **3.3 Metodologia de Desenvolvimento**

[Descrever Scrum, Kanban ou outra abordagem adotada, incluindo backlog, ciclos e acompanhamento.

#### **3.4 Mapeamento de stakeholders**

[descrever os barato aqui depois gustavos]

##### **3.4.1 Validação de Stakeholders**

A validação dos requisitos do gateway de pagamento foi realizada a partir das necessidades identificadas para os principais stakeholders envolvidos no projeto. Entre os participantes considerados estão a empresa PavPlas, seus funcionários, administradores, clientes, integrantes responsáveis pelo desenvolvimento, instituições financeiras, operadoras de pagamento, provedores de infraestrutura e equipe de suporte. A identificação desses grupos possibilitou compreender as diferentes necessidades relacionadas ao funcionamento da solução, considerando tanto os usuários diretos quanto os participantes responsáveis pela operação e processamento das transações.

Com base nessa análise, foram considerados como requisitos principais a possibilidade de realização de pagamentos pelos clientes, a consulta e o acompanhamento das transações, o gerenciamento das informações por usuários administrativos e a integração com serviços externos responsáveis pelo processamento dos pagamentos. Também foram considerados aspectos relacionados à segurança, confiabilidade,

facilidade de utilização e disponibilidade do sistema, uma vez que esses fatores influenciam diretamente a experiência dos clientes e a operação da empresa.

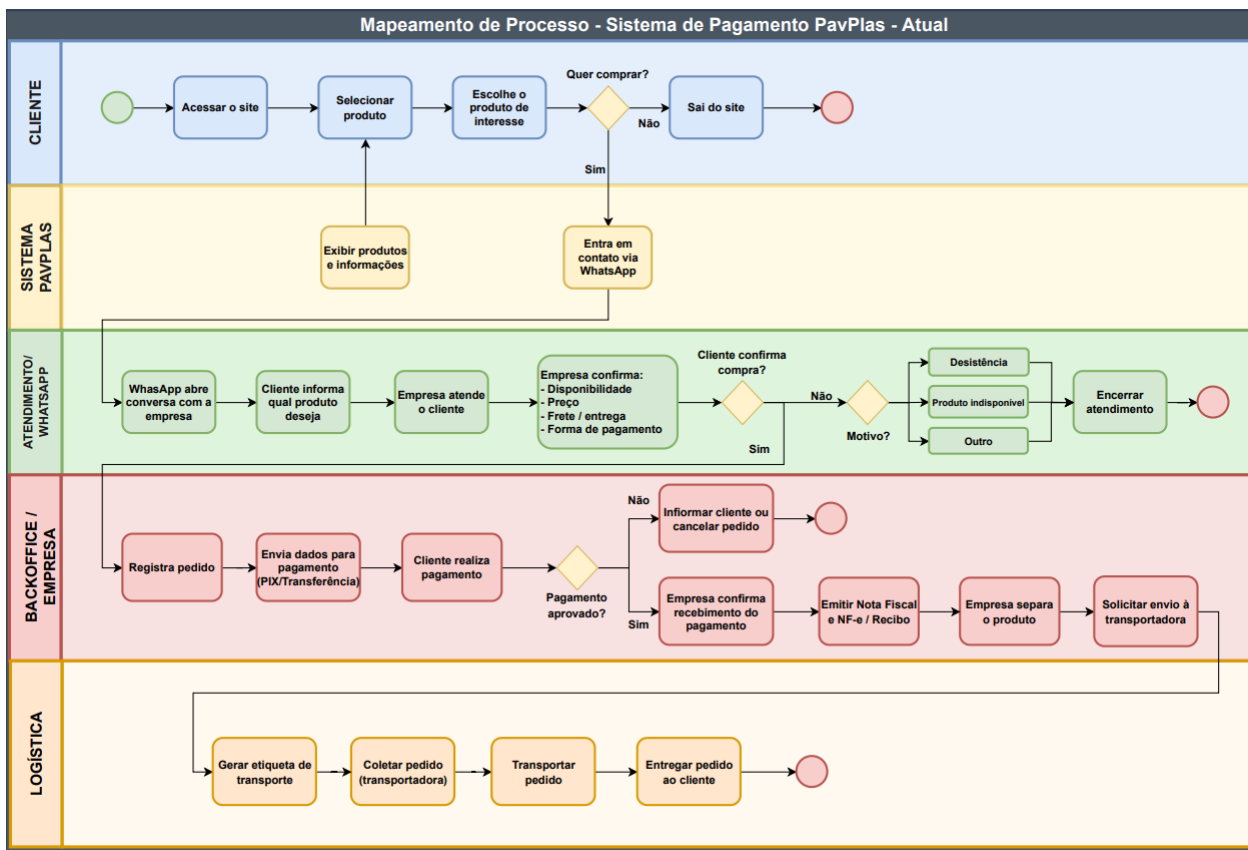
Para a PavPlas, o gateway deverá proporcionar maior controle e organização sobre as transações realizadas, permitindo que funcionários e administradores acompanhem informações relacionadas aos pagamentos. Para os clientes, a solução deverá oferecer um processo de pagamento simples, seguro e confiável. Além disso, o funcionamento do sistema deverá considerar a comunicação com instituições financeiras e operadoras de pagamento, bem como a infraestrutura necessária para manter o serviço disponível.

Dessa forma, os requisitos levantados apresentam compatibilidade com as necessidades identificadas para os stakeholders do projeto e poderão servir como base para as etapas posteriores de desenvolvimento da solução. Entretanto, a validação realizada nesta etapa possui caráter preliminar, sendo necessária a apresentação dos requisitos aos representantes responsáveis da PavPlas para confirmação, possíveis ajustes e aprovação antes da implementação definitiva das funcionalidades.

## **4 ANÁLISE DO PROBLEMA**

A PavPlas atua no setor de peças para máquinas industriais, mas seu processo de vendas é totalmente manual e dependente de interações humanas. O site funciona apenas como vitrine, sem funcionalidades de compra. Quando o cliente demonstra interesse, é redirecionado ao WhatsApp, onde a equipe consulta estoque e fretes em planilhas e sistemas isolados, negocia valores e envia dados bancários. O pagamento é feito via PIX ou transferência, com o cliente enviando o comprovante por chat. A equipe financeira confere manualmente a entrada do valor para, só então, autorizar a separação do produto, emissão da nota fiscal e coleta pela transportadora. Todo o fluxo é síncrono, fragmentado e sujeito a retrabalhos.

### **4.1 Processo Atual (As-Is)**



Atualmente, o processo de pagamento da PavPlas é realizado de forma manual. O site funciona apenas como catálogo, e o cliente precisa entrar em contato pelo WhatsApp para consultar estoque, negociar valores e definir o frete. Após a negociação, a empresa envia os dados para pagamento, que é realizado por **PIX ou transferência bancária**. O cliente então envia o comprovante pelo WhatsApp, e o setor financeiro realiza a conferência manual do recebimento.

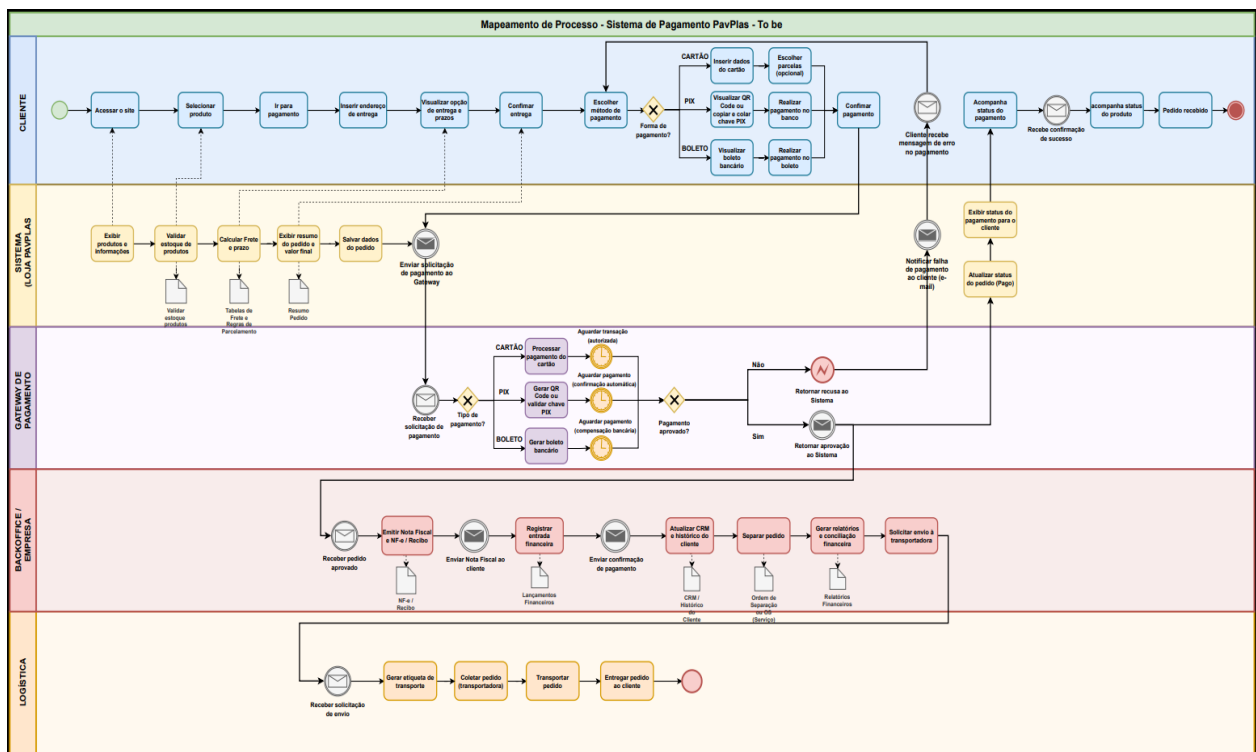
Após a confirmação do pagamento, o pedido é liberado para **separação do produto, emissão da nota fiscal e envio pela transportadora**. Esse processo depende de intervenção humana e não possui integração entre vendas, pagamento, estoque e logística, o que pode gerar retrabalho, demora e erros na conferência. **Mini fluxo: Site → WhatsApp → Negociação → PIX/Transferência → Envio do comprovante → Conferência financeira → Separação → NF-e → Transportadora**

## 4.2 Problemas Identificados

A partir da modelagem e análise crítica do fluxo operacional As-Is, evidenciaram-se gargalos e vulnerabilidades operacionais que travam a escalabilidade do negócio:

1. **Alta Dependência Humana e Limitação de Horário:** A conclusão de uma venda exige obrigatoriamente a presença ativa de um atendente comercial e de um analista financeiro. Vendas iniciadas fora do horário comercial ou em picos de demanda resultam em longas filas de espera, gerando desistências.
2. **Vulnerabilidade na Conciliação Financeira:** A conferência de comprovantes de pagamento via imagem ou texto abre margem para erros de interpretação humana e golpes de falsificação, comprometendo a segurança patrimonial da empresa.
3. **Silos de Informação e Retrabalho:** A ausência de comunicação sistêmica em tempo real entre o estoque físico, o catálogo virtual e o faturamento exige constante redigitação de informações cadastrais e pedidos, elevando a taxa de erro operacional.
4. **Fricção Elevada na Jornada do Cliente (UX):** Obrigar o comprador a trocar de plataforma para concluir uma transação gera quebra de confiança e adiciona etapas desnecessárias, reduzindo a taxa de conversão final da Plataforma.

#### **4.3 Processo Proposto (To-Be)**



Visando eliminar as ineficiências identificadas, foi elaborado um novo fluxograma centrado no cliente (cenário To-Be), que transforma o site institucional da PavPlas em uma plataforma de e-commerce automatizada e totalmente integrada a um sólido Gateway de Pagamento.

No modelo sugerido, a jornada de compra é totalmente independente. No ambiente virtual da loja, o consumidor escolhe as peças industriais que deseja e as adiciona ao carrinho de compras online. O sistema se integra em tempo real ao banco de dados de inventário, conferindo a disponibilidade do estoque de maneira imediata. No próximo passo, o cliente informa o endereço de entrega, ativando uma API que se conecta a tabelas logísticas dinâmicas para calcular o valor do frete e o tempo de entrega estimado. No momento do checkout, o Gateway de Pagamento assume o processamento da transação com segurança criptográfica de ponta a ponta. O usuário dispõe de opções de escolha automatizadas: PIX (com geração automática de QR Code dinâmico e chave do tipo "Copia e Cola"), boleto bancário (com compensação automatizada) ou cartão de crédito (com opção de parcelamento parametrizado). O

Gateway processa a requisição junto às instituições financeiras em segundos e devolve o veredito sistêmico.

Se a transação for autorizada, o sistema dispara gatilhos eletrônicos automatizados que operam de maneira paralela e integrada:

- Altera o status do pedido para "Pago" na área do cliente e notifica via e-mail corporativo.
- Realiza a baixa definitiva do produto no inventário do sistema.
- Envia os dados de faturamento para o sistema ERP, emitindo automaticamente a Nota Fiscal Eletrônica (NF-e) e enviando-a ao comprador.
- Gera instantaneamente a ordem de separação com etiqueta de postagem no setor de logística (backoffice), permitindo o acionamento célere da transportadora.
- Registra a entrada financeira nos relatórios contábeis, executando a conciliação automática sem qualquer interferência humana.

## 4.4 Requisitos Funcionais

### 4.4.1 Tabela de Requisitos Funcionais

| ID    | Requisito Funcional                                                          | Justificativa no Processo                   | Prioridade | Status    |
|-------|------------------------------------------------------------------------------|---------------------------------------------|------------|-----------|
| RF-01 | O sistema deve permitir o cadastro e a autenticação de clientes.             | Área do cliente e identificação no checkout | Alta       | A validar |
| RF-02 | O sistema deve exibir o catálogo de produtos com informações atualizadas.    | Catálogo virtual da PavPlas                 | Alta       | A validar |
| RF-03 | O sistema deve permitir adicionar, alterar e remover produtos do carrinho.   | Carrinho de compras proposto                | Alta       | A validar |
| RF-04 | O sistema deve consultar e exibir a disponibilidade dos produtos em estoque. | Validação automática do inventário          | Alta       | A validar |
| RF-05 | O sistema deve impedir a finalização de pedidos sem estoque suficiente.      | Redução de erros e vendas indisponíveis     | Alta       | A validar |
| RF-06 | O sistema deve coletar e validar o endereço de entrega do cliente.           | Etapa de entrega no checkout                | Alta       | A validar |

| ID    | Requisito Funcional                                                                          | Justificativa no Processo             | Prioridade | Status    |
|-------|----------------------------------------------------------------------------------------------|---------------------------------------|------------|-----------|
| RF-07 | O sistema deve calcular automaticamente o valor do frete.                                    | Integração com tabelas/API logística  | Alta       | A validar |
| RF-08 | O sistema deve apresentar a previsão de entrega.                                             | Retorno da integração logística       | Média      | A validar |
| RF-09 | O sistema deve permitir a seleção da modalidade de entrega disponível.                       | Definição do frete antes do pagamento | Média      | A validar |
| RF-10 | O sistema deve apresentar o resumo do pedido antes da confirmação.                           | Checkout integrado                    | Alta       | A validar |
| RF-11 | O sistema deve permitir pagamento por PIX.                                                   | Método previsto no modelo To-Be       | Alta       | A validar |
| RF-12 | O sistema deve gerar QR Code e código PIX Copia e Cola.                                      | Automação do pagamento por PIX        | Alta       | A validar |
| RF-13 | O sistema deve permitir pagamento por boleto bancário.                                       | Método previsto no modelo To-Be       | Alta       | A validar |
| RF-14 | O sistema deve gerar o boleto e disponibilizá-lo ao cliente.                                 | Processamento automatizado do boleto  | Alta       | A validar |
| RF-15 | O sistema deve permitir pagamento por cartão de crédito.                                     | Método previsto no modelo To-Be       | Alta       | A validar |
| RF-16 | O sistema deve apresentar as opções de parcelamento configuradas pela empresa.               | Parcelamento parametrizado            | Média      | A validar |
| RF-17 | O sistema deve enviar a transação                                                            | Integração da proposta                | Alta       | A validar |
| RF-18 | O sistema deve receber e registrar o resultado da transação retornado pelo gateway.          | Aprovação ou recusa do gateway        | Alta       | A validar |
| RF-19 | O sistema deve informar ao cliente se o pagamento foi aprovado, recusado ou está pendente.   | Retorno sistêmico do pagamento        | Alta       | A validar |
| RF-20 | O sistema deve atualizar automaticamente o status do pedido após a confirmação do pagamento. | Alteração para o estado "Pago"        | Alta       | A validar |
| RF-21 | O sistema deve enviar uma confirmação do pagamento e do pedido por e-mail.                   | Notificação automática ao cliente     | Média      | A validar |
| RF-22 | O sistema deve efetuar a baixa do produto no estoque após a confirmação do pagamento.        | Integração com inventário             | Alta       | A validar |
| RF-23 | O sistema deve enviar os dados do                                                            | Integração com faturamento            | Alta       | A validar |

| ID           | Requisito Funcional                                                                             | Justificativa no Processo            | Prioridade | Status    |
|--------------|-------------------------------------------------------------------------------------------------|--------------------------------------|------------|-----------|
|              | pedido e do cliente ao ERP.                                                                     |                                      |            |           |
| <b>RF-24</b> | O sistema deve solicitar a emissão automática da NF-e.                                          | Emissão fiscal proposta              | Alta       | A validar |
| <b>RF-25</b> | O sistema deve disponibilizar ou enviar a NF-e ao cliente.                                      | Entrega do documento fiscal          | Alta       | A validar |
| <b>RF-26</b> | O sistema deve gerar uma ordem de separação para o setor logístico.                             | Automação do backoffice              | Alta       | A validar |
| <b>RF-27</b> | O sistema deve gerar a etiqueta de postagem ou transporte.                                      | Preparação automatizada da expedição | Média      | A validar |
| <b>RF-28</b> | O sistema deve atualizar o pedido conforme o andamento da expedição.                            | Integração com logística             | Média      | A validar |
| <b>RF-29</b> | O sistema deve permitir que o cliente acompanhe o status do pedido.                             | Rastreabilidade na área do cliente   | Média      | A validar |
| <b>RF-30</b> | O sistema deve registrar a entrada financeira da venda confirmada.                              | Integração com o setor financeiro    | Alta       | A validar |
| <b>RF-31</b> | O sistema deve realizar a conciliação automática dos pagamentos.                                | Eliminação da conferência manual     | Alta       | A validar |
| <b>RF-32</b> | O sistema deve disponibilizar informações das vendas para relatórios financeiros.               | Controle financeiro e contábil       | Média      | A validar |
| <b>RF-33</b> | O sistema deve manter o histórico de pedidos do cliente.                                        | Rastreabilidade na área do cliente   | Média      | A validar |
| <b>RF-34</b> | O sistema deve permitir o gerenciamento de produtos, preços e estoque por usuários autorizados. | Manutenção do e-commerce             | Alta       | A validar |
| <b>RF-35</b> | O sistema deve permitir a consulta administrativa dos pedidos e de seus respectivos status.     | Controle operacional integrado       | Alta       | A validar |

#### 4.4.2 Regras de Negócio Associadas (A validar)

- **RN-01:** A baixa definitiva do estoque ocorrerá somente após o pagamento aprovado.
- **RN-02:** Pedidos com pagamento pendente poderão reservar estoque por um prazo determinado.

- **RN-03:** O pedido só poderá seguir para separação após a confirmação do pagamento.
- **RN-04:** As opções de parcelamento serão definidas e parametrizadas pela PavPlas.
- **RN-05:** O valor e prazo do frete dependerão do CEP de entrega, peso/dimensões dos produtos e tabela da transportadora.
- **RN-06:** Pagamentos recusados não gerarão ordem de separação nem emissão de NF-e.

## 4.5 Requisitos Administrativos (Backoffice)

### 4.5.1 Tabela de Requisitos Administrativos

| ID            | Requisito Administrativo                                                                               | Módulo / Setor                 | Descrição / Regra de Uso                                                                                               | Prioridade |
|---------------|--------------------------------------------------------------------------------------------------------|--------------------------------|------------------------------------------------------------------------------------------------------------------------|------------|
| <b>RAD-01</b> | O sistema deve permitir o controle de acesso baseado em perfis (RBAC).                                 | Segurança / Acesso             | Diferenciar permissões entre Administrador, Financeiro, Fiscal, Estoque e Atendimento.                                 | Alta       |
| <b>RAD-02</b> | O sistema deve permitir a autenticação segura com registro de logs de auditoria.                       | Segurança / Auditoria          | Registrar ações críticas (ex: alterações de preços, cancelamento de pedidos, estornos manuais).                        | Alta       |
| <b>RAD-03</b> | O sistema deve permitir o cadastro, edição e inativação de produtos e categorias.                      | Catálogo / Produtos            | Gestão de fotos, descrições, preços, dimensões, peso e status de visibilidade na loja.                                 | Alta       |
| <b>RAD-04</b> | O sistema deve permitir o ajuste manual e o controle de saldo de estoque.                              | Estoque / Inventário           | Ajustar quantidades por entrada de mercadoria, perda, avaria ou inventário periódico.                                  | Alta       |
| <b>RAD-05</b> | O sistema deve emitir alerta administrativo quando o estoque atingir o nível mínimo configurado.       | Estoque / Alertas              | Notificar os operadores sobre a necessidade de reposição de itens em baixa quantidade.                                 | Média      |
| <b>RAD-06</b> | O sistema deve permitir a visualização e gestão centralizada do ciclo de vida dos pedidos.             | Gestão de Pedidos              | Filtrar e consultar pedidos por status: <i>Pendente, Pago, Em Separação, Faturado, Enviado, Concluído, Cancelado</i> . | Alta       |
| <b>RAD-07</b> | O sistema deve permitir a alteração manual justificada de status do pedido por operadores autorizados. | Gestão de Pedidos              | Possibilitar intervenções operacionais (ex: cancelamento por solicitação do cliente).                                  | Alta       |
| <b>RAD-08</b> | O sistema deve permitir a configuração e parametrização das taxas e regras do gateway de pagamento.    | Financeiro / Gateway           | Configurar credenciais de API, número máximo de parcelas sem juros, desconto para PIX/boleto e prazos de expiração.    | Alta       |
| <b>RAD-09</b> | O sistema deve exibir o painel de conciliação financeira de vendas.                                    | <u>Financeiro</u> / Relatórios | Comparar valores brutos, taxas do gateway, valores líquidos a receber e status de                                      | Alta       |

| ID            | Requisito Administrativo                                                                         | Módulo / Setor        | Descrição / Regra de Uso                                                                                                   | Prioridade |
|---------------|--------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------|------------|
|               |                                                                                                  |                       | liquidação.                                                                                                                |            |
| <b>RAD-10</b> | O sistema deve permitir o reenvio manual de notificações (e-mail/WhatsApp) e links de pagamento. | Atendimento / Suporte | Gerar novamente e reenviar links de PIX, boleto ou segunda via de comprovante ao cliente.                                  | Média      |
| <b>RAD-11</b> | O sistema deve permitir a integração e sincronização manual/automática com o sistema ERP.        | Integração Fiscal/ERP | Monitorar a fila de envio de pedidos para faturamento e status da emissão de NF-e.                                         | Alta       |
| <b>RAD-12</b> | O sistema deve disponibilizar relatórios gerenciais e dashboards operacionais.                   | Gestão / BI           | Relatórios de vendas por período, produtos mais vendidos, ticket médio, abandono de carrinho e faturamento por modalidade. | Média      |
| <b>RAD-13</b> | O sistema deve permitir o gerenciamento de tabelas de frete e regras de envio.                   | Logística / Expedição | Parametrizar transportadoras parceiras, prazos adicionais de manuseio e taxas de frete fixo/regional.                      | Média      |

#### 4.6 Requisitos de Segurança

O Gateway PAVPLAS deverá integrar catálogo, pedidos, pagamentos, estoque, faturamento e logística, substituindo o processo manual atualmente realizado por meio de WhatsApp, planilhas, comprovantes e conferência financeira humana. O principal risco identificado é a falsificação de comprovantes de PIX ou transferência, capaz de liberar produtos sem que o pagamento tenha sido efetivamente recebido.

##### 4.6.1 Requisitos prioritários

| ID           | Área         | Requisito essencial                                                                                                          | Prioridade |
|--------------|--------------|------------------------------------------------------------------------------------------------------------------------------|------------|
| <b>RS-01</b> | Autenticação | O sistema deve utilizar contas individuais, sem compartilhamento de credenciais, com senhas armazenadas por hash adaptativo, | Crítica    |

|              |             |                                                                                                                                                                              |         |
|--------------|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
|              |             | limitação de tentativas e recuperação segura.                                                                                                                                |         |
| <b>RS-02</b> | MFA         | O painel interno deve exigir autenticação multifator para administradores, financeiros e usuários capazes de liberar pedidos, alterar valores ou configurar integrações.     | Crítica |
| <b>RS-03</b> | Sessões     | Sessões devem utilizar cookies <u>Secure</u> , <u>HttpOnly</u> e <u>SameSite</u> , expiração por inatividade, logout efetivo e invalidação após troca de senha ou revogação. | Alta    |
| <b>RS-04</b> | Autorização | O acesso deve seguir menor privilégio e negação por padrão, com validação de autorização no servidor e não apenas na interface.                                              | Crítica |
| <b>RS-05</b> | Papéis      | Devem existir, no mínimo, os papéis Cliente, Comercial, Financeiro, Estoque/Expedição, Faturamento, Transportadora e Administrador.                                          | Alta    |
| <b>RS-06</b> | Segregação  | Comercial não pode confirmar pagamentos; Financeiro não deve liberar expedição sozinho; Administrador não deve apagar evidências de auditoria.                               | Crítica |
| <b>RS-07</b> | Isolamento  | O cliente deve visualizar somente seus próprios dados, pedidos, pagamentos, comprovantes e documentos.                                                                       | Crítica |
| <b>RS-08</b> | Pagamento   | A confirmação deve ocorrer por consulta segura ao PSP/banco e por webhook autenticado. O comprovante enviado pelo cliente não deve ser fonte única de confirmação.           | Crítica |

|              |                          |                                                                                                                                       |         |
|--------------|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------|---------|
| <b>RS-09</b> | Integridade              | Cada cobrança deve possuir identificador único, valor esperado, pedido associado e validade. Divergências devem bloquear a liberação. | Crítica |
| <b>RS-10</b> | Webhooks                 | Webhooks devem validar assinatura, timestamp, origem quando aplicável e proteção contra replay.                                       | Crítica |
| <b>RS-11</b> | Idempotência             | Repetições ou atrasos de eventos não podem gerar pagamentos, reservas, baixas ou expedições duplicadas.                               | Crítica |
| <b>RS-12</b> | Estados                  | O pedido deve seguir máquina de estados, impedindo passagem direta para expedição sem pagamento confirmado e etapas obrigatórias.     | Crítica |
| <b>RS-13</b> | Criptografia em trânsito | Toda comunicação entre cliente, gateway, serviços internos e terceiros deve utilizar HTTPS/TLS com certificados válidos.              | Crítica |
| <b>RS-14</b> | Criptografia em repouso  | Dados pessoais sensíveis, tokens, comprovantes, backups e documentos devem ser criptografados em repouso.                             | Alta    |
| <b>RS-15</b> | Segredos                 | Chaves de API, certificados e credenciais devem ser armazenados em cofre de segredos, separados por ambiente e sujeitos a rotação.    | Crítica |
| <b>RS-16</b> | API                      | A API deve validar autenticação, autorização, tipos, formatos, tamanho, limites e conteúdo de todos os dados no servidor.             | Alta    |
| <b>RS-17</b> | Ataques                  | Devem ser aplicados controles contra SQL/NoSQL injection, XSS, CSRF, abuso                                                            | Crítica |

|              |                  |                                                                                                                                                                  |            |
|--------------|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
|              |                  | de endpoints, força bruta e upload malicioso.                                                                                                                    |            |
| <b>RS-18</b> | Disponibilidade  | Endpoints críticos devem possuir rate limiting, timeout, retry controlado, circuit breaker e filas duráveis para integrações.                                    | Alta       |
| <b>RS-19</b> | Privacidade      | Devem ser coletados apenas os dados necessários, com finalidade, base legal, aviso de privacidade e controle de compartilhamento com PSP, NF-e e transportadora. | Alta       |
| <b>RS-20</b> | Retenção         | Dados, comprovantes e logs devem possuir prazo de retenção e descarte seguro conforme necessidade operacional e obrigações legais.                               | Média/alta |
| <b>RS-21</b> | Auditoria        | O sistema deve registrar logins, falhas, alterações de pedidos, mudanças de preço, eventos de pagamento, aprovações, webhooks e integrações.                     | Crítica    |
| <b>RS-22</b> | Proteção de logs | Logs devem ser protegidos contra alteração e exclusão por usuários operacionais, com mascaramento de senhas, tokens, dados bancários e documentos.               | Alta       |
| <b>RS-23</b> | Monitoramento    | Devem existir alertas para tentativas repetidas de login, elevação de privilégio, falhas de webhook, divergência de pagamento e comportamento anômalo.           | Alta       |
| <b>RS-24</b> | Continuidade     | Backups devem ser criptografados, possuir controle de acesso, verificação de                                                                                     | Alta       |

|              |                 |                                                                                                                                                           |      |
|--------------|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|------|
|              |                 | integridade e testes periódicos de restauração.                                                                                                           |      |
| <b>RS-25</b> | Desenvolvimento | O ciclo de desenvolvimento deve incluir revisão de código, análise de dependências, testes de segurança e correção de vulnerabilidades antes da produção. | Alta |

### 3. Fluxo seguro de pagamento e pedido

O fluxo recomendado é: **criação do pedido → geração de cobrança única → pagamento → recebimento de evento autenticado do PSP → validação do valor e do pedido → confirmação idempotente → reserva de estoque → separação → emissão de NF-e → despacho.**

O comprovante enviado pelo cliente pode ser anexado para fins de atendimento, mas não deve alterar automaticamente o status para “pago”. Quando o PSP estiver indisponível, houver divergência de valor, evento repetido ou assinatura inválida, o pedido deve permanecer bloqueado e ser encaminhado ao Financeiro.

A aprovação manual excepcional deve exigir justificativa, evidência e, para valores acima de limite definido pela PavPlas, aprovação de dois usuários distintos. Toda mudança de estado deve registrar usuário ou serviço responsável, data, origem, pedido, evento associado e resultado.

#### 4.6.1 Matriz mínima de permissões

| Perfil         | Pode fazer                                                               | Não pode fazer                                                       |
|----------------|--------------------------------------------------------------------------|----------------------------------------------------------------------|
| <b>Cliente</b> | Consultar catálogo, criar pedido e acompanhar seus pagamentos e entregas | Acessar dados de terceiros, confirmar pagamento ou liberar expedição |

|                           |                                                                        |                                                                  |
|---------------------------|------------------------------------------------------------------------|------------------------------------------------------------------|
| <b>Comercial</b>          | Criar pedidos, negociar valores dentro dos limites e acompanhar vendas | Confirmar recebimento, liberar expedição ou administrar usuários |
| <b>Financeiro</b>         | Consultar transações e tratar divergências                             | Alterar logs ou liberar sozinho operações fora da política       |
| <b>Estoque/ Expedição</b> | Separar e despachar após regra de pagamento                            | Alterar valor ou confirmar pagamento                             |
| <b>Faturamento</b>        | Emitir e consultar NF-e                                                | Alterar pagamento ou permissões                                  |
| <b>Transportadora</b>     | Consultar remessas atribuídas e atualizar transporte                   | Acessar pedidos não atribuídos ou dados financeiros              |
| <b>Administrador</b>      | Configurar usuários e sistema, com MFA e auditoria                     | Apagar evidências ou substituir aprovação sem justificativa      |

#### 4.6.2 Critérios de aceite e implantação

Antes da entrada em produção, devem ser executados testes de acesso entre clientes, tentativa de acesso a funções sem permissão, recuperação de senha, MFA, expiração de sessão, repetição de webhook, divergência de valor, duplicidade de eventos, upload de arquivos maliciosos, rate limiting, injeção e restauração de backup.

A implantação deve ocorrer em quatro etapas. Primeiro, devem ser implementados os bloqueadores de fraude: validação do pagamento pelo PSP, webhooks autenticados, máquina de estados, idempotência, RBAC, MFA, TLS e gestão de segredos. Em seguida, devem ser aplicados os controles de API, auditoria, mascaramento e monitoramento. Na terceira etapa, devem ser tratados privacidade, retenção, backups e contingência. Por fim, devem ser institucionalizados testes contínuos, gestão de vulnerabilidades e exercícios de resposta a incidentes.

A entrada em produção deve ser condicionada à ausência de vulnerabilidades críticas abertas, à aprovação da matriz de permissões pelos responsáveis de cada área,

à validação das integrações financeiras e à existência de procedimento para indisponibilidade do PSP, estoque, NF-e ou transportadora.

#### 4.7 Requisitos Não Funcionais

**Quadro - Requisitos não funcionais do gateway de pagamentos**

| ID            | Categoria               | Definição mensurável                                                                                                                                                                                  |
|---------------|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>RNF-01</b> | Desempenho              | A tela de pagamento deve responder em até 3 segundos em 95% das requisições. A confirmação recebida do provedor deve aparecer no pedido em até 10 segundos.                                           |
| <b>RNF-02</b> | Disponibilidade         | O gateway deve ter disponibilidade mensal mínima de 99,5%, desconsiderando manutenções avisadas. Se o provedor estiver indisponível, o usuário deve receber uma mensagem clara.                       |
| <b>RNF-03</b> | Segurança e privacidade | Toda comunicação deve usar HTTPS/TLS. Senhas e chaves devem ficar fora do código. O sistema não deve armazenar dados completos de cartão e deve coletar apenas os dados necessários, seguindo a LGPD. |
| <b>RNF-04</b> | Confiabilidade          | Repetir uma requisição não pode gerar cobrança duplicada. Cada pagamento deve possuir identificador único, status controlado e histórico de alterações.                                               |
| <b>RNF-05</b> | Escalabilidade          | A aplicação deve suportar pelo menos 100 solicitações simultâneas, com taxa de erro inferior a 1%, e permitir aumento de instâncias sem alterar o código.                                             |

|               |                 |                                                                                                                                                                                  |
|---------------|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>RNF-06</b> | Usabilidade     | O fluxo deve funcionar em celular e computador, informar valor e status antes da confirmação e apresentar mensagens compreensíveis em caso de erro.                              |
| <b>RNF-07</b> | Observabilidade | As operações devem gerar registros com data, identificador do pedido, status e código de erro, sem registrar dados sensíveis. Falhas repetidas devem gerar alerta para a equipe. |
| <b>RNF-08</b> | Recuperação     | Os registros de pedidos e pagamentos devem ter backup diário. A meta de recuperação é RPO de 24 horas e RTO de 4 horas.                                                          |

| ID            | Como validar                                                                                    | Evidência esperada                                                                  |
|---------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>RNF-01</b> | Realizar teste de carga com 100 acessos e medir o tempo de resposta e de atualização do status. | Relatório do teste com resposta em até 3 segundos e confirmação em até 10 segundos. |
| <b>RNF-02</b> | Monitorar o serviço e simular a indisponibilidade do provedor.                                  | Relatório de disponibilidade e captura da mensagem apresentada ao usuário.          |
| <b>RNF-03</b> | Verificar HTTPS, variáveis de ambiente, registros e banco de dados.                             | Checklist sem chaves no código e sem dados sensíveis armazenados.                   |

|               |                                                                             |                                                                            |
|---------------|-----------------------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>RNF-04</b> | Enviar duas vezes a mesma solicitação usando a mesma chave de idempotência. | Somente uma cobrança criada e o evento registrado no histórico.            |
| <b>RNF-05</b> | Executar 100 solicitações simultâneas no ambiente de teste.                 | Taxa de erro inferior a 1% e serviço estável durante o teste.              |
| <b>RNF-06</b> | Testar o fluxo em celular e computador, incluindo erro e cancelamento.      | Capturas das telas e checklist do fluxo concluído.                         |
| <b>RNF-07</b> | Gerar um pagamento aprovado e outro com falha.                              | Registros rastreáveis pelo pedido, sem dados sensíveis, e alerta da falha. |
| <b>RNF-08</b> | Restaurar uma cópia do banco de dados em ambiente de teste.                 | Registro da restauração e conferência dos dados recuperados.               |

## **5 MODELAGEM E ARQUITETURA**

[Desenvolver o conteúdo deste capítulo com base no projeto real.]

### **5.1 Visão Geral do Sistema**

O sistema proposto para a PavPlas consiste em uma solução integrada de vendas e pagamentos, desenvolvida com o objetivo de automatizar etapas que atualmente dependem de atendimento manual e da utilização do WhatsApp. A solução permitirá que o cliente realize o processo de compra diretamente pelo ambiente virtual, desde a escolha dos produtos até a realização do pagamento, reduzindo a necessidade de intervenção manual durante a operação.

O fluxo principal terá início com a consulta ao catálogo de produtos, permitindo que o cliente selecione os itens desejados e os adicione ao carrinho de compras. Durante o processo, o sistema deverá verificar a disponibilidade dos produtos em estoque, coletar as informações necessárias para entrega e calcular o valor do frete. Após a confirmação dos dados do pedido, o cliente será direcionado para a etapa de pagamento, na qual poderá selecionar entre as modalidades disponibilizadas pela PavPlas, como PIX, boleto bancário e cartão de crédito.

O gateway de pagamento será responsável por intermediar a comunicação entre o sistema da PavPlas e os serviços financeiros utilizados para o processamento das transações. Após o envio do pagamento, o sistema deverá receber o resultado da operação e informar ao cliente se a transação foi aprovada, recusada ou permanece pendente. Nos pagamentos confirmados, o status do pedido será atualizado automaticamente, permitindo a continuidade das etapas de faturamento, separação e envio do produto.

Além das funcionalidades destinadas aos clientes, o sistema deverá oferecer recursos administrativos para acompanhamento dos pedidos, pagamentos, estoque e demais informações relacionadas às vendas. A solução também prevê integração com os setores financeiro, de estoque, faturamento e logística, possibilitando maior

centralização das informações e redução de atividades repetitivas. Dessa forma, o sistema busca proporcionar maior controle operacional para a PavPlas e uma experiência de compra mais simples, segura e organizada para seus clientes.

## **5.2 Arquitetura da Solução**

[Apresentar arquitetura geral e justificar as decisões.]

## **5.3 Casos de Uso**

[Inserir diagrama e descrição dos casos de uso relevantes.]

## **5.4 Diagrama de Classes**

[Inserir diagrama e explicar as principais entidades e relacionamentos.]

## **5.5 Modelo de Dados**

[Inserir DER/modelo lógico e explicar as principais tabelas.]

## **5.6 Fluxo de Pagamento**

[Descrever passo a passo o processamento, atualização de status e retorno ao sistema.]

## **6 SEGURANÇA**

[Desenvolver o conteúdo deste capítulo com base no projeto real.]

### **6.1 Autenticação e Autorização**

[Explicar como usuários e sistemas são autenticados e quais permissões possuem.]

### **6.2 Proteção de Dados**

[Explicar minimização, proteção de informações e cuidados com dados sensíveis.]

### **6.3 Criptografia**

[Descrever uso de HTTPS/TLS e outras técnicas efetivamente utilizadas.]

### **6.4 Controle de Acesso**

[Descrever perfis, permissões, segregação e auditoria.]

### **6.5 LGPD**

[Relacionar o tratamento de dados às obrigações e princípios aplicáveis.]

## 7 CONCLUSÃO

[Desenvolver o conteúdo deste capítulo com base no projeto real.]

### 7.1 Considerações Finais

[Retomar problema, objetivo e principais resultados, demonstrando se o objetivo foi alcançado.]

### 7.2 Limitações

[Registrar limitações técnicas, de escopo, dados, tempo, integrações ou infraestrutura.]

### 7.3 Trabalhos Futuros

[Propor evoluções: novos provedores, Pix, conciliação, antifraude, observabilidade, escalabilidade, mensageria etc.]

## REFERÊNCIAS

ABPMP. BPM CBOK: Guia para o Gerenciamento de Processos de Negócio Corpo Comum de Conhecimento. ABPMP, 2013.

HAMMER, Michael. **Reengenharia: a revolução no gerenciamento**. Rio de Janeiro: Campus, 1994.

STRIPE. **Benefícios de gateway de pagamentos para empresas**. Disponível em: <https://stripe.com/br/resources/more/five-key-benefits-of-payment-gateways-for-businesses>

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **NIST SP 800-63-4**

OPEN WEB APPLICATION SECURITY PROJECT (OWASP). **OWASP Application Security Verification Standard**.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.